

Trail of Bits Sample Audit Report
Project: Sample Vault

Executive Summary

This is a synthetic Trail of Bits style report used for testing.

1. Reentrancy in withdraw allows fund theft

Severity: High

Difficulty: Medium

Type: Data Validation

Description

The withdraw function in target/contracts/Vault.sol:L42-L60 calls an external token before updating internal accounting state. An attacker can re-enter withdraw and drain the vault.

Exploit Scenario

Alice deposits and then re-enters withdraw via a malicious token.

Recommendation

Apply the checks-effects-interactions pattern: update internal balances before the external token call. Consider adding a non-reentrancy modifier to the withdraw function.

2. Integer overflow in fee calculation results in loss

Severity: Medium

Difficulty: Low

Type: Arithmetic

Description

The fee calculation in target/contracts/Fee.sol:L100 multiplies two unchecked uint256 values which can overflow for large inputs.

Recommendation

Use Solidity 0.8+ checked arithmetic or SafeMath for the fee calculation. Add unit tests covering the boundary cases.